

README – Kit de Encuesta SSVc y Gestión de Vulnerabilidades

Bienvenido al improbable pero necesario kit de encuesta sobre cómo su organización prioriza vulnerabilidades, con especial cariño por SSVc, KEV, Vulnrichment, EPSS y esa simpática entidad llamada NIS2. [web:19][web:24][web:33][web:22][web:25]

1. Contenido del kit

El kit está compuesto por los siguientes documentos en formato Markdown:

1. encuesta-ssvc.md – Modelo de encuesta integral para responsables de la organización.
2. guia-metodologica-ssvc.md – Explicación detallada de qué mide la encuesta y cómo.
3. narrativa-explicativa-ssvc.md – Texto narrativo para acompañar y contextualizar la encuesta.
4. mapeo-preguntas-normativa.md – Mapeo de bloques de preguntas con NIS2, SSVc y buenas prácticas.
5. plantilla-excel-igm-roi.md – Diseño de hoja Excel para calcular el IGM y el ROI.
6. plantilla-reporte-ejecutivo-ssvc.md – Guion de presentación ejecutiva tipo PowerPoint.

2. Objetivos

- Medir de forma estructurada la madurez de la organización en gestión de vulnerabilidades y priorización basada en riesgo. [web:27][web:32][web:33]
- Evaluar el grado de adopción (real, no solo declarativo) del marco SSVc y el uso de datos de explotación y contexto (KEV, Vulnrichment, EPSS). [web:19][web:22][web:25][web:23][web:20][web:24]
- Conectar estos resultados con los requisitos de NIS2 y otras obligaciones regulatorias. [web:33][web:39][web:36]
- Facilitar la construcción de un caso de negocio cuantificable para mejorar capacidades y automatización. [web:27][web:32][web:41]

3. Cómo usar el kit

7. Personalizar la encuesta (encuesta-ssvc.md) con la terminología y matices propios de su organización o sector (sin diluir el contenido, si puede ser).
8. Distribuir la encuesta a los responsables adecuados y fijar un plazo razonable de respuesta.
9. Codificar las respuestas en la plantilla Excel descrita en plantilla-excel-igm-roi.md, calculando IGM y métricas clave.
10. Analizar resultados siguiendo la guia-metodologica-ssvc.md y el mapeo-preguntas-normativa.md.
11. Preparar un reporte ejecutivo para Alta Dirección con la ayuda de plantilla-reporte-ejecutivo-ssvc.md.
12. Repetir el ejercicio de forma periódica (anual o semestral) para medir progreso y justificar inversiones.

4. Adaptación y extensiones

El kit está pensado para ser adaptable:

- Puede integrarse en programas existentes de auditoría interna o frameworks como NIST CSF o ISO 27001. [web:33][web:32]
- Puede ampliarse con secciones específicas para OT, IoT o sectores regulados concretos, reutilizando los mismos principios de SSVC. [web:20][web:41]
- Puede combinarse con análisis empíricos de incidentes para ajustar ponderaciones y mejorar el modelo de IGM. [web:16][web:27][web:32]

5. Referencias clave

- CERT/CC – Documentación oficial de SSVC, bootstrapping, decisiones y modelos. [web:24][web:30][web:5][web:19][web:37]
- CISA – KEV, Vulnrichment y uso de SSVC en priorización nacional. [web:6][web:22][web:25][web:28][web:19]
- NIS2 – Requisitos de gestión de vulnerabilidades, gobernanza y reporting. [web:33][web:39][web:36]
- Informes industriales sobre métricas, estado de gestión de vulnerabilidades y ROI. [web:27][web:32][web:35][web:38][web:41]

6. Nota final

Este kit no garantiza la iluminación súbita ni el cumplimiento automático, pero ofrece una estructura razonablemente sólida para pasar de discusiones abstractas sobre “riesgo” a preguntas concretas, respuestas medibles y decisiones que se pueden defender delante de un regulador, un auditor o, en el peor de los casos, una comisión parlamentaria.

Si después de usarlo su organización decide seguir priorizando parches “por olfato”, al menos lo hará con plena conciencia de causa.